



**FACULTAD DE POSTGRADO
TRABAJO FINAL DE GRADUACIÓN**

**METODOLOGÍA DE INTELIGENCIA DE AMENAZAS (CTI)
BASADA EN MITRE ATT&CK Y GOBERNANZA DE DATOS
PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN
HONDURAS.**

SUSTENTADO POR:

**EDER JOSUE ARTICA CRUZ |
SUYAPA INES MATAMOROS PACHECO**

Comentado [JASL1]: No incluir números de cuenta

PREVIA INVESTIDURA AL TÍTULO DE

**MÁSTER EN
CIBERSEGURIDAD**

TEGUCIGALPA, FRANCISCO MORAZAN, HONDURAS, C.A.

JUNIO, 2026

**UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA
UNITEC**

FACULTAD DE POSTGRADO

AUTORIDADES UNIVERSITARIAS

**RECTORA
ROSALPINA RODRÍGUEZ**

**VICERRECTOR ACADÉMICO NACIONAL
JAVIER ABRAHAM SALGADO LEZAMA**

**SECRETARIO GENERAL
ROGER MARTÍNEZ MIRALDA**

**DECANA FACULTAD DE POSTGRADO
ANA DEL CARMEN RETTALLY VARGAS**

**METODOLOGÍA DE INTELIGENCIA DE AMENAZAS (CTI)
BASADA EN MITRE ATT&CK Y GOBERNANZA DE DATOS
PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN
HONDURAS.**

**TRABAJO PRESENTADO EN CUMPLIMIENTO DE LOS
REQUISITOS EXIGIDOS PARA OPTAR AL TÍTULO DE
MÁSTER EN
CIBERSEGURIDAD**

**ASESOR
SERVIO PALACIOS**

MIEMBROS DE LA TERNA:

**NOMBRE COMPLETO EVALUADOR 1
NOMBRE COMPLETO EVALUADOR 2
NOMBRE COMPLETO EVALUADOR 3**

Comentado [JASL2]: Sin título académico

DERECHOS DE AUTOR

© Copyright 2023
Eder Josué Artica Cruz
Suyapa Ines Matamoras Pacheco

Todos los derechos son reservados.

**AUTORIZACIÓN DEL AUTOR(ES) PARA LA CONSULTA,
REPRODUCCIÓN PARCIAL O TOTAL Y PUBLICACIÓN
ELECTRÓNICA DEL TEXTO COMPLETO DE TESIS DE POSTGRADO**

Señores

CENTRO DE RECURSOS PARA EL APRENDIZAJE Y LA INVESTIGACIÓN (CRAI)

UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA (UNITEC)

Estimados Señores:

Yo, XXXXXXXXXX, de Tegucigalpa, (o San Pedro Sula, o La Ceiba) autor del trabajo de postgrado titulado: XXXXXXXXXXXXXXXXXXXXXXXXXXXX, presentado y aprobado en XXXX, como requisito previo para optar al título de máster en XXXXXXXXXXXXXXXXXXXX y reconociendo que la presentación del presente documento forma parte de los requerimientos establecidos del programa de maestrías de la Universidad Tecnológica Centroamericana (UNITEC), por este medio autorizo a las Bibliotecas de los Centros de Recursos para el Aprendizaje y la Investigación (CRAI) de UNITEC, para que con fines académicos puedan libremente registrar, copiar o utilizar la información contenida en él, con fines educativos, investigativos o sociales de la siguiente manera:

- 1) Los usuarios puedan consultar el contenido de este trabajo en las salas de estudio de la biblioteca y/o la página Web de la Universidad.
- 2) Permita la consulta y/o la reproducción a los usuarios interesados en el contenido de este trabajo, para todos los usos que tengan finalidad académica, ya sea en formato CD o digital desde Internet, Intranet, etc., y en general en cualquier otro formato conocido o por conocer.

Comentado [JASL3]: Nombre completo de cada alumno

Comentado [JASL4]: Título del trabajo

Comentado [JASL5]: Mes, Año

Comentado [JASL6]: Nombre de la maestría

De conformidad con lo establecido en los artículos 9.2, 18, 19, 35 y 62 de la Ley de Derechos de Autor y de los Derechos Conexos; los derechos morales pertenecen al autor y son personalísimos, irrenunciables, imprescriptibles e inalienables. Asimismo, el autor cede de forma ilimitada y exclusiva a UNITEC la titularidad de los derechos patrimoniales. Es entendido que cualquier copia o reproducción del presente documento con fines de lucro no está permitida sin previa autorización por escrito de parte de UNITEC.

En fe de lo cual se suscribe el presente documento en la ciudad de _____, a los ____ días del mes de _____ del año _____

Nombre completo

Número de cuenta

*** La autorización firmada se encuentra adjunta a mí expediente**



FACULTAD DE POSTGRADO

METODOLOGÍA DE INTELIGENCIA DE AMENAZAS (CTI) BASADA EN MITRE ATT&CK Y GOBERNANZA DE DATOS PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS.

Eder Josué Artica Cruz
Suyapa Ines Matamoros
Pacheco

Resumen

Xxx
xx
xx
xx
xx
xx
xx
xx
xx
xx
xx
xx
xx
xx
xx

Palabras claves: (xxxxx)

Comentado [JASL7]: Un solo párrafo

Comentado [JASL8]: Máximo 5 palabras claves, en orden alfabético



GRADUATE SCHOOL

METODOLOGÍA DE INTELIGENCIA DE AMENAZAS (CTI) BASADA EN MITRE ATT&CK Y GOBERNANZA DE DATOS PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS.

Eder Josue Artica Cruz
Suyapa Ines Matamoros
Pacheco

Abstract

XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX

Palabras claves: (xxxxx)

Comentado [JASL9]: Un solo párrafo

Comentado [JASL10]: Máximo 5, en inglés, en orden alfabético

DEDICATORIA

Introduzca la dedicatoria. Introduzca la dedicatoria. Introduzca la dedicatoria. Introduzca
la dedicatoria. Introduzca la dedicatoria. Introduzca la dedicatoria. Introduzca la dedicatoria.
Introduzca la dedicatoria. Introduzca la dedicatoria. Introduzca la dedicatoria. Introduzca la
dedicatoria.

AGRADECIMIENTO

Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su
agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca
aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento.
Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su
agradecimiento. Introduzca aquí su agradecimiento.

ÍNDICE DE CONTENIDO

Comentado [JASL11]: Actualizar una vez terminado el documento.

DEDICATORIA	x
AGRADECIMIENTO	xi
ÍNDICE DE CONTENIDO	1
CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN	2
1.1 INTRODUCCIÓN	2
1.2 ANTECEDENTES DEL PROBLEMA	3
1.3 DEFINICIÓN DEL PROBLEMA	3
1.3.1 Enunciado del problema	3
1.3.2 Formulación del problema	4
1.3.3 Preguntas de investigación	4
1.4 OBJETIVOS DEL PROYECTO	5
1.5 JUSTIFICACIÓN	5
1.6 CONTRIBUCIONES Y ALCANCES	7
1.7. LIMITACIONES	8
CAPÍTULO II. MARCO TEÓRICO	9
2.1 ANÁLISIS DE LA SITUACIÓN ACTUAL	9
2.2 CONCEPTUALIZACIÓN	9
2.3 TEORÍAS DE SUSTENTO	11
2.3.1 BASES TEÓRICAS	11
2.4 MARCO LEGAL	14
Bibliografía	16

CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN

1.1 INTRODUCCIÓN

El impacto global de la gestión de la ciberseguridad obliga a redirigir la mirada hacia el contexto local, donde las estrategias de defensa deben alinearse con las amenazas específicas y el entorno operativo en el que se desarrollan. En un panorama donde los incidentes de ransomware y las disrupciones a servicios esenciales van en aumento, ha quedado en evidencia que las defensas perimetrales estáticas son insuficientes. Si bien los Centros de Operaciones de Seguridad (SOC) buscan evolucionar hacia posturas proactivas mediante el consumo de Inteligencia de Amenazas Cibernéticas (CTI), se enfrentan a un desafío paralizante: la saturación y fragmentación de los reportes globales, un fenómeno documentado como la "cámara de eco" de la inteligencia de amenazas.

En el contexto hondureño, las organizaciones operan con recursos y presupuestos de ciberseguridad finitos, haciendo que su evaluación de actores de amenaza y enfoque de gestión de los insumos que estos puedan brindar a través de las capas de ciberseguridad y los diferentes eventos no estén siendo enfocados al contexto local y si a enfoques globales lo cual infiere en evaluaciones de riesgos sesgadas y posibilidades de impacto no acorde con la explotabilidad que actores de amenaza este ejecutando. Sumado a esto, los modelos teóricos de evaluación de riesgo apoyados en el marco MITRE ATT&CK suelen fracasar en implementaciones reales al asumir un entorno con datos de auditoría perfectos. La realidad técnica de los SOC locales se caracteriza por la opacidad, la incompatibilidad de formatos de logs y un alto nivel de ruido en los eventos del sistema. Sin una correlación temporal adecuada y una limpieza previa, la inteligencia ingerida pierde su valor procesable.

Para resolver esta brecha, esta investigación propone una Metodología de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK y Gobernanza de Datos para la Priorización de Actores de Amenaza en Honduras. Al fusionar modelos cuantitativos de riesgo con estrategias de normalización eficiente de registros en tiempo real, este trabajo establece un puente entre la inteligencia cruda y la detección operativa. Este enfoque permite a las organizaciones optimizar sus esfuerzos, enfocando sus capacidades de defensa exclusivamente en los adversarios que representan un peligro inminente y comprobado para la región.

1.2 ANTECEDENTES DEL PROBLEMA

La gestión analítica de la ciberseguridad en entornos operativos contemporáneos se enfrenta a una asimetría estructural entre la masividad de datos recolectados y la capacidad de respuesta táctica de los Centros de Operaciones de Seguridad (SOC). Históricamente, las organizaciones han priorizado el almacenamiento indiscriminado de registros lógicos (logs) bajo premisas perimetrales reactivas. Sin embargo, este enfoque induce a un colapso de capacidades conocido como fatiga de alertas. De acuerdo con las evidencias empíricas recolectadas por (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las pantallas de los analistas, lo cual degrada los tiempos de contención operativa y abre vectores críticos que facilitan movimientos laterales sofisticados.

El problema sistémico se agrava al evaluar el aprovisionamiento de Inteligencia de Ciberamenazas (CTI). Las plataformas analíticas convencionales ingieren flujos de datos comerciales globales provistos de forma genérica por los fabricantes. Tal como demuestran cuantitativamente (Suarez-Roman et al., 2026), el ecosistema actual de reportes de amenazas padece un severo efecto de cámara de eco (Echo Chamber Effect), caracterizado por la fragmentación, el solapamiento de indicadores atómicos y un profundo sesgo comercial que prioriza las dinámicas de ataques materializados en potencias industrializadas. Al contrastar este sesgo con el diagnóstico regional de (Pavón et al., 2022) sobre la brecha tecnológica y la disparidad de madurez en ciberdefensa de las economías latinoamericanas, se vuelve lógicamente imperativa la transición hacia un modelo metodológico capaz de calibrar el cálculo de riesgos probabilísticos en función del entorno geopolítico local. El estado del arte analizado por (Yang et al., s. f.) señala que el modelado dinámico de Tácticas, Técnicas y Procedimientos (TTPs) fundamentado en marcos como MITRE ATT&CK es la ruta científica para neutralizar el comportamiento del adversario; no obstante, su viabilidad predictiva está intrínsecamente supuesta sobre la existencia de fuentes de datos puras, íntegras y normalizadas en su origen.

1.3 DEFINICIÓN DEL PROBLEMA

1.3.1 Enunciado del problema

Los Centros de Operaciones de Seguridad (SOC) de las organizaciones de infraestructura crítica en Honduras operan bajo un enfoque reactivo e ineficiente ante el

incremento de Ransomware dirigido, viéndose incapacitados para tomar acciones preventivas. Esta situación se deriva de la adopción de inteligencia global fragmentada (*cámara de eco*) y de la baja calidad semántica, duplicidad e incompatibilidad técnica de los logs ingeridos por el SIEM. El ruido en los eventos del sistema corrompe las ecuaciones de riesgo y desactiva el funcionamiento de los grafos predictivos de ataque, impidiendo la detección temprana de movimientos laterales y de técnicas de evasión como el Controls Override, dejando expuestos los servicios esenciales del país.

1.3.2 Formulación del problema

¿De qué manera el diseño de una metodología que integre la Inteligencia de Amenazas basada en MITRE ATT&CK y un marco de gobernanza de datos permite al SOC priorizar de forma proactiva a los actores de amenaza de Ransomware en las organizaciones de infraestructura crítica en Honduras?

1.3.3 Preguntas de investigación

- ¿Cómo se pueden adaptar cuantitativamente las ecuaciones de probabilidad de ocurrencia geopolítica regional ($\$LO = II + RI + 0.2\$$) de Ahmed et al. (2022) al perfil de los adversarios activos en Honduras?
- ¿Qué componentes de control técnico debe incluir un framework de gobernanza de datos para certificar y normalizar semánticamente las fuentes de logs en origen, mitigando el ruido analítico en el SIEM?
- ¿De qué forma el modelado de grafos de ataque basados en la dimensión de "Access and Trust" de Georgiadou et al. (2021) permite predecir los movimientos laterales tácticos ante la ejecución de técnicas de Controls Override?

1.4 OBJETIVOS DEL PROYECTO

- **Objetivo General:**
 - Desarrollar una metodología analítica de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK y Gobernanza de Datos para optimizar las capacidades de priorización proactiva de actores de amenaza de Ransomware dentro de los Centros de Operaciones de Seguridad (SOC) en organizaciones de infraestructura crítica de Honduras.
- **Objetivos Específicos:**
- **Adaptar y calibrar cuantitativamente** el modelo matemático de probabilidad de ocurrencia geopolítica ($\$LO = II + RI + 0.2\$$) propuesto por Ahmed et al. (2022) al perfil táctico y motivacional de los adversarios de Ransomware activos en Honduras.
- **Diseñar un framework técnico** de gobernanza, normalización semántica y certificación de calidad para fuentes de logs en origen, mitigando el ruido analítico antes de la fase de correlación de eventos en el SIEM.
- **Modelar las trayectorias de riesgo y movimientos laterales** mediante la construcción de Grafos de Ataque dinámicos, evaluando la resistencia de los componentes de control de acceso exigidos por la norma NIST SP 800-207 frente a tácticas de evasión avanzada (*Controls Override*).
- **Evaluar el desempeño de la metodología unificada** mediante escenarios simulados de Ransomware avanzado para medir la reducción de la fatiga de alertas en el SOC.

1.5 JUSTIFICACIÓN

La presente investigación se justifica de manera multidimensional para responder a los retos críticos de seguridad informática y gobernanza que enfrentan las organizaciones que sostienen los servicios esenciales en Honduras.

Desde una justificación científica, este estudio aborda una brecha de conocimiento crítica detectada en la literatura internacional (Ahmed et al., 2022; Jiang et al., 2025). Los modelos

matemáticos predictivos de amenazas globales asumen de forma idealista que los datos corporativos de entrada son homogéneos y perfectos. Esta investigación rompe ese paradigma y genera nuevo conocimiento al demostrar teórica y experimentalmente que la precisión analítica de las fórmulas de riesgo de ciberinteligencia depende de un marco previo de gobernanza que certifique el no repudio y la integridad de los logs en la fuente de origen.

En el ámbito de la justificación tecnológica, la metodología propone una innovación concreta: un framework de ingeniería de características (feature engineering) y normalización semántica automatizada para registros de auditoría. Esta herramienta dota a las infraestructuras de monitoreo tradicionales (SIEM) de capacidades avanzadas de filtrado de ruido y traducción algorítmica automatizada hacia técnicas de MITRE ATT&CK, permitiendo una automatización simétrica de la defensa.

Socialmente, la justificación social se fundamenta en la protección directa del Compromiso al Bienestar Humano (\$CHWS) de la población hondureña. Sectores como energía, telecomunicaciones, banca y salud representan la espina dorsal del país; un ataque de Ransomware exitoso en estas infraestructuras no solo compromete datos confidenciales, sino que interrumpe la provisión de servicios públicos vitales. Esta tesis dota a la nación de un modelo metodológico soberano y geográficamente acotado para salvaguardar la estabilidad social.

Finalmente, la justificación económica responde a la necesidad de optimizar los recursos financieros en entornos con presupuestos restrictivos. Las organizaciones hondureñas no poseen el capital para competir contra las masivas inversiones tecnológicas de países desarrollados. Priorizar científicamente a los atacantes reales de la región permite al SOC enfocar sus inversiones de respuesta y configuraciones analíticas exclusivamente en las amenazas de mayor probabilidad de impacto, disminuyendo drásticamente las pérdidas financieras directas (\$DFL\$) por paradas operativas no programadas y multas legales (\$LF\$), maximizando el retorno de inversión en ciberdefensa.

Para validar científicamente la viabilidad de la investigación y responder a las exigencias formalistas de posgrado, el sistema defensivo propuesto se define formalmente bajo los siguientes supuestos analíticos e invariantes de ingeniería:

Definición Formal del Sistema: Sea D el flujo total de telemetría y eventos lógicos ingerido por el Centro de Operaciones de Seguridad (SOC), tal que $D = D_p \cup D_r$, donde D_p representa el conjunto de datos semánticamente puros y conformes, y D_r representa el subconjunto de ruido

estructural, registros degradados o alterados por técnicas de evasión de bitácoras (Controls Override).

Teorema I (Optimización Analítica del SOC). Si el motor de correlación lógica del SIEM procesa un flujo de datos D donde el coeficiente de ruido semántico en origen tiende al vacío ($D_r \rightarrow \emptyset$) a través de un pipeline automatizado de gobernanza que valida continuamente la telemetría, y las ecuaciones probabilísticas de Ocurrencia (LO, Likelihood of Occurrence) están calibradas para el entorno geográfico local mediante pesos deterministas ($LO = \llbracket II \rrbracket_{\text{Honduras}} + \llbracket RI \rrbracket_{\text{Honduras}} + 0.2$), entonces la Tasa de Falsos Positivos (TFP) del SOC disminuye monótonamente y la precisión analítica de los grafos de ataque tiende al 100%.

Corolario 1.1 (Axioma de Confianza Zero Trust). La fidelidad predictiva de una alerta de seguridad es inversamente proporcional a la entropía y degradación semántica de su fuente de origen. Ningún algoritmo matemático de Inteligencia de Ciberamenazas puede calcular un perfil de adversario válido si los registros de auditoría de los componentes violan el principio de verificación continua estipulado en la norma arquitectónica NIST SP 800-207.

1.6 CONTRIBUCIONES Y ALCANCES

La presente investigación se justifica de manera multidimensional para responder a los retos críticos de seguridad informática y gobernanza que enfrentan las organizaciones que sostienen los servicios esenciales en Honduras.

Desde una justificación científica, este estudio aborda una brecha de conocimiento crítica detectada en la literatura internacional (Ahmed et al., 2022; Jiang et al., 2025). Los modelos matemáticos predictivos de amenazas globales asumen de forma idealista que los datos corporativos de entrada son homogéneos y perfectos. Esta investigación rompe ese paradigma y genera nuevo conocimiento al demostrar teórica y experimentalmente que la precisión analítica de las fórmulas de riesgo de ciberinteligencia depende de un marco previo de gobernanza que certifique el no repudio y la integridad de los logs en la fuente de origen.

En el ámbito de la justificación tecnológica, la metodología propone una innovación concreta: el uso del framework MITRE ATT&CK, como punto de alza para validar la adaptabilidad de las infraestructuras de monitoreo tradicionales (SOC) de capacidades avanzadas de filtrado de ruido y traducción algorítmica automatizada hacia técnicas de MITRE ATT&CK,

permitiendo una automatización de caso de uso ante detección de actores de amenaza.

1.7. LIMITACIONES

Con el propósito de delimitar el área de estudio y garantizar la viabilidad del protocolo, se establecen las siguientes restricciones del proyecto:

- **Entornos productivos reales:** La metodología y el prototipo de software desarrollado no serán implementados ni testeados en infraestructuras analíticas en producción ni en redes vivas de ninguna empresa u organización activa en el país, debido a restricciones estrictas de confidencialidad y para mitigar riesgos de continuidad de negocio.
- **Solución comercial empaquetada:** La investigación no contempla el desarrollo de un producto de software comercial, un SIEM propietario o una plataforma empaquetada lista para el mercado.
- **Vectores de ataque excluidos:** El análisis analítico y el modelado predictivo se centrarán de forma exclusiva en campañas de actores de amenazas dirigido, excluyendo del alcance otras amenazas masivas o genéricas como ataques distribuidos de denegación de servicio (DDoS) a nivel de infraestructura de red o campañas masivas de spam no focalizado.

CAPÍTULO II. MARCO TEÓRICO

2.1 ANÁLISIS DE LA SITUACIÓN ACTUAL.

La protección de las infraestructuras críticas en Honduras —que abarcan sectores vitales como energía, telecomunicaciones, salud y el sistema financiero— se encuentra en una encrucijada operativa crítica. La gestión de ciberseguridad de los entornos locales opera predominantemente bajo esquemas tradicionales de naturaleza reactiva, lo que limita su capacidad para anticipar intrusiones complejas ejercidas por actores de amenaza a través de las diferentes Tácticas, Técnicas y Procedimientos (TTPs) que estos implementan. De acuerdo con las evaluaciones macro sobre la madurez de la ciberseguridad en América Latina, las capacidades de defensa e intercambio de inteligencia táctica muestran brechas estructurales profundas debido a restricciones de presupuesto y a la escasez de analistas especializados (Pavón et al., 2022)

Esta situación se ve agravada por la evolución tecnológica y la gestión de empresas en el entorno nacional, lo cual ha atraído la presencia de actores hostiles avanzados cuyas campañas dirigidas demuestran que las defensas estáticas perimetrales ya no son capaces de contener movimientos laterales complejos. Como demuestran empíricamente (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las capacidades analíticas de los equipos de respuesta (IT/OT), induciendo a una severa fatiga de alertas que dilata los tiempos de mitigación y vulnera la disponibilidad de los servicios esenciales.

Ante la falta de un marco soberano de priorización, las organizaciones locales importan flujos genéricos de Inteligencia de Amenazas (CTI) comerciales que saturan las consolas de monitoreo con Indicadores de Compromiso (IoCs) desconectados del contexto nacional (Suarez-Roman et al., 2026). El resultado es un Centro de Operaciones de Seguridad (SOC) con casos de uso no acordes con una gestión analítica de las TTPs u operación del actor, generando un procesamiento ineficiente y una capacidad sesgada de entender y reaccionar ante la presencia de un incidente de ciberdefensa en el entorno real.

2.2 CONCEPTUALIZACIÓN

Para establecer el soporte semántico e interpretativo de esta investigación, la construcción del marco conceptual aborda la evolución dinámica y el consenso actual de los constructos

centrales, superando la estructura de un glosario pasivo de términos.

El concepto de Inteligencia de Amenazas Cibernéticas (CTI) Táctica ha evolucionado significativamente desde la recolección estática y reactiva de firmas atómicas (como direcciones IP o hashes de malware) hacia el modelado conductual abstracto del adversario. Bajo la perspectiva actual de (Villalón Huerta, 2023) y la revisión sistemática, el consenso de la comunidad científica dictamina que la ciberinteligencia táctica debe fundamentarse en la categorización de Tácticas, Técnicas y Procedimientos (TTPs) a través de marcos estructurados como MITRE ATT&CK®. Esta dimensión trasciende los indicadores atómicos tradicionales al concentrarse en capturar las pautas repetibles de comportamiento del atacante, permitiendo interceptar intrusiones avanzadas de forma proactiva con independencia de las herramientas de software mutables que use el adversario.

De igual forma, la Gobernanza de Datos de Auditoría ha transitado desde un enfoque archivístico de cumplimiento normativo pasivo hacia un control de calidad técnico preventivo dentro de la arquitectura de seguridad. En la actualidad, se define como el conjunto coordinado de políticas, validaciones sintácticas y pipelines algorítmicos aplicados directamente en el origen del dato. Su propósito es certificar la calidad, integridad estructural, completitud y el no repudio de los registros de actividad (logs) emitidos por dispositivos heterogéneos antes de su ingesta en los motores analíticos, neutralizando el ruido sintáctico que propicia desviaciones en el diagnóstico defensivo.

Por su parte, el fenómeno denominado Fatiga de Alertas del SOC se conceptualiza científicamente como la degradación de la capacidad de atención y respuesta cognitiva del analista debido a la sobreexposición a volúmenes masivos de alertas de seguridad redundantes o falsos positivos. Su origen radica en el diseño de reglas de correlación y casos de uso basados en umbrales estáticos y firmas aisladas, omitiendo el contexto de un vector de ataque multidimensional, la secuencia conductual de una TTP y el perfil específico del actor que dirige la campaña de intrusión.

Finalmente, las variables de Entorno Geopolítico, Vectores de Ataque y el Nivel de Madurez de Ciberseguridad Local constituyen constructos interdependientes que determinan la probabilidad real de que un sector estratégico sea seleccionado como objetivo prioritario por un adversario. La literatura científica moderna establece que el riesgo no es una probabilidad

abstracta global, sino un cálculo condicionado por dinámicas socioeconómicas territoriales, motivaciones de extorsión financiera regionales y el grado de capacidad regulatoria y técnica que posee un país específico para identificar, proteger, detectar y recuperar sus activos esenciales frente a incidentes a gran escala.

2.3 TEORÍAS DE SUSTENTO

2.3.1 BASES TEORICAS

El núcleo metodológico y la innovación profesionalizante de la presente propuesta unifican e interconectan marcos teóricos complementarios estudiados a lo largo de la maestría, aplicándolos articuladamente a una realidad concreta del entorno nacional: la optimización y ciberdefensa de las infraestructuras críticas y sectores estratégicos de Honduras. En primera instancia, se adopta el Modelo de Riesgo Cuantitativo Orientado al Adversario de (Ahmed et al., 2022). Esta teoría matemática descarta las evaluaciones cualitativas subjetivas convencionales y las sustituye por ecuaciones probabilísticas ligadas a Grafos de Ataque dinámicos. El modelo establece que la probabilidad de ocurrencia de una amenaza (LO, Likelihood of Occurrence) es una función directa de las capacidades del atacante parametrizadas geográficamente mediante el Interés de la Industria (II) y el Interés de la Región (RI), adicionando un factor de calibración determinista para entornos reales corporativos expresado en la ecuación:

$$LO = II + RI + 0.2$$

Este cálculo se intercepta analíticamente con la trayectoria táctica del adversario para predecir el tiempo de compromiso del activo. Esta investigación aplica formalmente dicha matemática ejecutando su calibración adaptativa para Honduras, asignando pesos específicos a II y RI según el perfil de riesgo de los sectores nacionales de la Banca, Energía y Gobierno.

La segunda teoría de soporte es el marco arquitectónico de Arquitectura Zero Trust (ZTA), normado internacionalmente por la publicación especial NIST SP 800-207 (Rose et al., 2020). Este enfoque defensivo elimina el principio de confianza implícita basado en la ubicación lógica o perímetro de red, exigiendo una verificación continua, dinámica y explícita de cada sujeto, dispositivo y flujo de datos dentro de la infraestructura. Su operativización mandata que los Motores de Políticas (Policy Engine) responsables de autorizar los accesos y alertamientos

analíticos se alimenten de una telemetría ambiental íntegra, continua y de alta fidelidad.

Finalmente, se incorpora el Marco de Riesgo Técnico-Cultural (Georgiadou et al., 2021). Este enfoque postula que la vulnerabilidad de las redes de infraestructuras críticas, especialmente en entornos donde convergen tecnologías de la información (TI) y tecnologías de operación (OT), está fuertemente ligada a variables organizacionales y operativas. Explica cómo las deficiencias analíticas y la falta de correlación contextual facilitan que los atacantes ejecuten técnicas de evasión avanzada como Controls Override (manipulación o borrado de bitácoras) para saltar lateralmente hacia sistemas industriales y SCADA aprovechando la distracción analítica.

Articulación Coherente de las Metodologías: La pertinencia de esta unión reside en la codependencia técnica de los marcos. El algoritmo predictivo de CTI de Ahmed et al. (2022) colapsará y emitirá falsos positivos si procesa datos ruidosos, corruptos o alterados por técnicas de evasión, cumpliendo el axioma de ingeniería de 'Garbage In, Garbage Out'. Por lo tanto, la metodología de Gobernanza de Datos diseñada bajo los principios Zero Trust de la norma NIST SP 800-207 actúa como el pipeline de control y validación semántica preanalítica que limpia los logs en la fuente de origen antes de su transmisión. Al articular secuencialmente ambos enfoques, se dota a los SOC's hondureños de una telemetría pura, permitiendo que las ecuaciones calibradas de Ahmed calculen con precisión matemática cuál actor representa el riesgo más alto e inmediato, reduciendo drásticamente la fatiga de alertas y optimizando los recursos del país.

2.3.2 METODOLOGIAS DESARROLLADAS

En el estado del arte de la ciberdefensa se identifican tres enfoques metodológicos alternativos utilizados en procesos de investigación similares, cuyas limitaciones críticas justifican el desarrollo de esta propuesta unificada:

- Modelado Estocástico Basado en CVSS: Enfoque clásico centrado en la severidad intrínseca y estática de las vulnerabilidades informáticas. Su gran limitación metodológica es que asume un entorno defensivo pasivo, ignorando las capacidades dinámicas del adversario, el historial conductual de sus campañas y el contexto geográfico o sectorial específico de la organización evaluada.

- Mapeo Automatizado mediante Procesamiento de Lenguaje Natural (NLP): Metodologías de vanguardia emplean modelos de aprendizaje automático e inteligencia artificial para extraer TTPs a partir de reportes de CTI en texto libre crudo. A pesar de su innovación algorítmica, padecen el denominado Supuesto de Ingesta Ideal, pues su precisión analítica decae exponencialmente si las fuentes de telemetría y logs de auditoría originales del SOC de destino contienen ruido estructural, duplicidades sintácticas o incompatibilidades de formato.
- Gráficos de Conocimiento Defensivo (MITRE D3FEND™): Enfoques orientados a estructurar de manera semántica las contramedidas técnicas de ingeniería defensiva (como el engaño, el aislamiento o el análisis de linaje de procesos). Si bien organizan de manera excelente la matriz de respuestas frente a MITRE ATT&CK®, carecen de ecuaciones probabilísticas dinámicas para priorizar de forma predictiva qué contramedidas desplegar primero en entornos operativos con recursos financieros y humanos altamente restrictivos.

Este análisis crítico del estado del arte revela la Brecha de Investigación (Research Gap): la ausencia de un marco metodológico híbrido que unifique las ecuaciones predictivas de riesgo geopolítico (CTI táctica) con pipelines estrictos de gobernanza de datos para la normalización, validación semántica y limpieza de registros lógicos directamente en la fuente de origen dentro de los Centros de Operaciones de Seguridad de economías emergentes.

2.3.3 INSTRUMENTOS UTILIZADOS

La operativización de los modelos y metodologías analizados en la literatura científica previa evidencia el empleo de instrumentos técnicos específicos que sirven como marcos de referencia instrumental para la presente investigación:

- Matrices de Comportamiento Adversario MITRE ATT&CK®: Empleo unificado de las

matrices conductuales de Enterprise e ICS (Sistemas de Control Industrial) como un instrumento taxonómico granular para mapear las tácticas del atacante en entornos híbridos y rastrear la progresión de movimientos laterales.

- Algoritmos de Normalización en Tiempo Real (Gerhards, 2016): Utilización de estructuras de clasificación basadas en Grafos Acíclicos Dirigidos (PDAG) en lugar de expresiones regulares tradicionales. Este instrumento de software es el que permite procesar masivamente mensajes de logs heterogéneos bajo condiciones de workloads masivos sin introducir latencia o retrasos en el motor de ingesta del SIEM.
- Instrumentos de Control Temporal y Enrutamiento: Incorporación conceptual de motores de enrutamiento avanzado (syslog-ng) e instrumentos de monitoreo temporal de eventos basados en la inyección de mensajes tipo heartbeat (latidos de estado) validados en los principios de motores como VTEC de AMD o PROID. Estos instrumentos de software permiten aislar el ruido de los eventos benignos del sistema y alertar de forma automatizada sobre la interrupción u opacidad de los flujos de datos debida a técnicas de evasión del intruso.

2.4 MARCO LEGAL

El desarrollo y la futura implementación de la metodología propuesto interactúan directamente con un estricto ecosistema regulatorio y de cumplimiento sectorial (Compliance) aplicable en la República de Honduras, obligando a las organizaciones a transicionar desde auditorías manuales reactivas hacia controles de ingeniería continuos.

2.4.1 Marco Regulatorio Nacional

Normas para la Gestión del Riesgo Tecnológico de la CNBS (Resolución GE No. 342/2018, Artículo 21): Emitida por la Comisión Nacional de Bancos y Seguros, esta normativa posee fuerza de ley y es de cumplimiento obligatorio para todas las instituciones del sistema financiero, asegurador y de pensiones que operan en Honduras. El Artículo 21 dictamina de forma mandatoria la creación, mantenimiento y custodia inalterable de Pistas

de Auditoría (Logs) detalladas para registrar cualquier acceso, modificación o transacción lógica en las plataformas y servicios críticos del negocio. En el escenario analizado en esta investigación, la "fatiga de alertas" provocada por el ruido semántico de los registros degradados genera ceguera operativa, haciendo que el SOC pase por alto anomalías reales. Esto sitúa a las entidades en una posición de incumplimiento legal latente ante el ente regulador, exponiéndolas a severas sanciones punitivas y multas económicas. El insumo final de esta tesis —el pipeline de software unificado— automatiza y asegura la legibilidad de estas pistas de auditoría exigidas por el Artículo 21, al tiempo que calibra localmente el algoritmo de riesgo (Ahmed et al., 2022) mediante las variables regionales (RI e II) para proveer la proactividad analítica que la CNBS demanda.

2.4.2 Estándares Internacionales Vinculantes en el Entorno Nacional

- Estándar de Seguridad de Datos de la Industria de Tarjetas de Pago (*Official PCI Security Standards Council Site - Document*, s. f.): Este estándar internacional constituye una obligación jurídica en Honduras mediante vínculos contractuales comerciales que condicionan de forma mandatoria la operación de cualquier entidad que procese, almacene o transmita datos de tarjetas de crédito o débito. El Requisito 10 (Rastrear y supervisar todos los accesos a los recursos de red y a los datos de los titulares de tarjetas) obliga legalmente a los SOC's organizacionales a centralizar y revisar los logs de seguridad al menos una vez al día. La problemática identificada en este estudio demuestra que la dependencia de feeds globales redundantes expuestos en el Echo Chamber Effect (Suarez-Roman et al., 2026) satura las consolas analíticas con falsos positivos, haciendo humanamente imposible dicha revisión diaria. El incumplimiento de PCI-DSS faculta a las marcas de tarjetas a revocar de inmediato la licencia de operación de la entidad bancaria, forzando al cese de sus transacciones en el país. El prototipo de software propuesto actúa como un motor de cumplimiento automatizado del Requisito 10, consolidando los flujos masivos de logs en subgrafos limpios de ataque (Peng & Zhang, s. f.) para interceptar intrusiones dirigidas en tiempo real.

- Norma Internacional ISO/IEC 27001:2022 (Controles A.8.10 y A.8.14): Si bien nace como un marco internacional, ISO 27001 se transforma en una exigencia legal de cumplimiento en el entorno hondureño mediante decretos de modernización institucional y pliegos de condiciones obligatorios para licitaciones tecnológicas del Estado y del sector corporativo masivo. El Control A.8.10 (Seguridad en los registros de auditoría) exige que las bitácoras lógicas estén estrictamente protegidas contra la modificación, eliminación o falsificación. Asimismo, el Control A.8.14 (Reducción de vulnerabilidades técnicas) demanda el monitoreo constante ante amenazas emergentes. La fatiga analítica actual impide que las fuentes de telemetría sean verificadas oportunamente en el SIEM, abriendo una brecha donde técnicas de evasión como Controls Override corrompen la evidencia. El pipeline de gobernanza desarrollado bajo los principios de verificación continua de la norma NIST SP 800-207 inspecciona sintácticamente cada log en el origen, proveyendo de manera automatizada la pista matemática inalterable que el auditor de ISO requiere para certificar la infraestructura nacional.

Bibliografía

- Ahmed, M., Panda, S., Xenakis, C., & Panaousis, E. (2022). MITRE ATT&CK-driven Cyber Risk Assessment. *Proceedings of the 17th International Conference on Availability, Reliability and Security*, 1-10. <https://doi.org/10.1145/3538969.3544420>
- Georgiadou, A., Mouzakitis, S., & Askounis, D. (2021). Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework. *Sensors*, 21(9), 3267. <https://doi.org/10.3390/s21093267>
- Official PCI Security Standards Council Site—Document. (s. f.). Recuperado 17 de junio de 2026, de https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0_1-LA.pdf
- Pavón, E., Guaytarilla, L. F., Cueva, C., & Durango, K. (2022). Perspectives on cybersecurity and cyber defense in Latin America. *ATH*, 26-37. <https://doi.org/10.47460/athenea.v3i9.43>
- Peng, Y., & Zhang, T. (s. f.). *AutoLabel: Automated Fine-Grained Log Labeling for Cyber Attack Dataset*

Generation.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication (SP) 800-207). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-207>

Suarez-Roman, M., Marchiori, F., Conti, M., & Tapiador, J. (2026, mayo 21). *The CTI Echo Chamber: Fragmentation, Overlap, and Vendor Specificity in Twenty Years of Cyber Threat Reporting* (Número arXiv:2602.17458). arXiv. <https://doi.org/10.48550/arXiv.2602.17458>

Villalón Huerta, A. (2023). *Modeling of Advanced Threat Actors: Characterization, Categorization and Detection* [Phdthesis, Universitat Politècnica de València].

<https://doi.org/10.4995/Thesis/10251/193855>

Yang, L., Chen, Z., Wang, C., Zhang, Z., & Booma, S. (s. f.). *True Attacks, Attack Attempts, or Benign Triggers? An Empirical Measurement of Network Alerts in a Security Operations Center.*